

Security+ 2.3 · SQL Injection

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — SQL Injection (5:09) · [vídeo original](#)
[↗](#) · [YouTube](#) [↗](#)

Injetar SQL num campo de entrada: 'OR 1=1--' pula o login; DROP TABLE apaga a tabela; UNION SELECT extrai dado. Defesa: PREPARED STATEMENT (parameterized query), input validation, WAF, menor privilégio no banco. Nunca concatenar string pra query.

Highlights que a prova cobra

- SQLi = input injetado no query sem sanitizar
- Defesa nº1: prepared statement / parameterized query
- Defesa nº2: menor privilégio (o banco do user não tem Drop Table)

Dicas de prova

- 'input concatenated into a SQL query' = SQL injection
- 'parameterized queries prevent' = defesa do SQLi (prepared statement)

Cenário clássico: Cenário típico: 'login aceito com input' OR '1'='1' = classic SQL injection.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Injeção de comando SQL num campo de login explora principalmente a falta de:

- A)** Criptografia do disco
- B)** Validação de entrada (input)
- C)** Backup
- D)** Antivírus

2. Injetar script malicioso numa página pra rodar no navegador de OUTROS usuários:

- A)** XSS (Cross-Site Scripting)
- B)** CSRF
- C)** SQLi
- D)** Buffer overflow

3. No sistema CVSS 3.1, uma vulnerabilidade com pontuação 9.8 é classificada como:

- A)** Baixa
- B)** Média
- C)** Alta
- D)** Crítica

4. Cenário corporativo (SQL Injection): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SQLi = input injetado no query sem sanitizar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: SQLi = input injetado no query sem sanitizar...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (SQL Injection): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Defesa nº1: prepared statement / parameterized query'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Defesa nº1: prepared statement / parameterized query...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (SQL Injection): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Defesa nº2: menor privilégio (o banco do user não tem Drop Table)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Defesa nº2: menor privilégio (o banco do user não tem Drop Table)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (SQL Injection): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'input concatenated into a SQL query' = SQL injection'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'input concatenated into a SQL query' = SQL injection...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (SQL Injection): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'parameterized queries prevent' = defesa do SQLi (prepared statement)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'parameterized queries prevent' = defesa do SQLi (prepared statement)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (SQL Injection): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'login aceito com input' OR '1'='1' = classic SQL injection.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário típico: 'login aceito com input' OR '1'='1' = classic SQL injection...

10. Cenário corporativo (SQL Injection): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SQLi = input injetado no query sem sanitizar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: SQLi = input injetado no query sem sanitizar...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) B — Validação de entrada (input).** SQL injection acontece quando a aplicação NÃO valida/sanitiza o que o usuário digita e joga direto no banco. Validação de entrada é a defesa.
- 2) A — XSS (Cross-Site Scripting).** XSS injeta JavaScript que roda no navegador da vítima. Defesa: sanitizar/escapar a saída. SQLi ataca o banco; CSRF força ação autenticada.
- 3) D — Crítica.** CVSS classifica: Baixa (0.1-3.9), Média (4.0-6.9), Alta (7.0-8.9), Crítica (9.0-10.0). Uma pontuação de 9.8 é considerada Crítica.
- 4) B — Implementar a solução correspondente: SQLi = input injetado no query sem sanitiz.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (SQL Injection): SQLi = input injetado no query sem sanitizar. As demais alternativas configuram violações graves de conformidade ou fal
- 5) A — Implementar a solução correspondente: Defesa nº1: prepared statement / parameter.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (SQL Injection): Defesa nº1: prepared statement / parameterized query. As demais alternativas configuram violações graves de conformidad
- 6) C — Implementar a solução correspondente: Defesa nº2: menor privilégio (o banco do u.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (SQL Injection): Defesa nº2: menor privilégio (o banco do user não tem Drop Table). As demais alternativas configuram violações graves d
- 7) B — Implementar a solução correspondente: 'input concatenated into a SQL query' = SQ.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (SQL Injection): 'input concatenated into a SQL query' = SQL injection. As demais alternativas configuram violações graves de conformida
- 8) C — Implementar a solução correspondente: 'parameterized queries prevent' = defesa d.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (SQL Injection): 'parameterized queries prevent' = defesa do SQLi (prepared statement). As demais alternativas configuram violações grav
- 9) D — Implementar a solução correspondente: Cenário típico: 'login aceito com input' O.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (SQL Injection): Cenário típico: 'login aceito com input' OR '1'='1' = classic SQL injection.. As demais alternativas configuram violaçõ
- 10) A — Implementar a solução correspondente: SQLi = input injetado no query sem sanitiz.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (SQL Injection): SQLi = input injetado no query sem sanitizar. As demais alternativas configuram violações graves de conformidade ou fal